

Manual 36 — Implementación controlada de la LGPD de Brasil

****Idioma:**** Español de América Latina (es-419)

****Línea base controlada:**** Lei nº 13.709/2018 (LGPD) vigente y regulaciones vinculantes de la ANPD verificadas el 31-08-2026.

****Límite:**** Estatuto, regulación vinculante de ANPD, guía/enforcement, ley sectorial, contrato y práctica organizacional permanecen separados. Esta es una traducción de proyecto no oficial y no constituye asesoría jurídica ni aprobación regulatoria.

Chapter 01 — Propósito, alcance y jerarquía controlada de fuentes

Use la LGPD consolidada y los instrumentos vinculantes de la ANPD como fuentes controlantes para tratamiento cubierto. Clasifique guía, enforcement, reglas sectoriales, contratos y procedimientos internos por su estatus y fecha.

Mantenga registro fechado de fuentes, responsable de aplicabilidad, change watch y evidencia de reverificación previa al release.

Chapter 02 — Aplicabilidad, alcance territorial y análisis jurisdiccional

Documento por qué una actividad está dentro o fuera del alcance territorial de la LGPD, considerando tratamiento en Brasil, oferta a personas en Brasil y recolección en Brasil, además de exclusiones y overlays sectoriales.

Conserve evaluación de aplicabilidad, hechos, reviewer responsable, excepciones y triggers de reevaluación.

Chapter 03 — Datos personales, datos sensibles y conceptos de tratamiento

Mantenga definiciones controladas para datos personales, sensibles, anonimizados, tratamiento, base de datos, titular, controlador, operador y conceptos relacionados. Resuelva conflictos terminológicos antes de que lleguen a notices, contratos, sistemas o incidentes.

Conserve glosario, reglas de clasificación, ejemplos, decisiones y cambios terminológicos.

Chapter 04 — Controlador, operador, encargado y roles de accountability

Identifique responsabilidades reales de controlador y operador y mantenga la gobernanza del encargado/DPO requerida por LGPD y ANPD. La asignación debe seguir autoridad decisoria y hechos, no solo etiquetas contractuales.

Conserve matrices de roles, nombramientos, canales de contacto, instrucciones, escalamiento y registros de accountability.

Chapter 05 — Modelo de gobernanza, políticas y responsabilidades de privacidad

Establezca gobernanza aprobada con accountability ejecutiva, ownership de políticas, roles operativos, escalamiento de riesgo, assurance y management review periódico. Integre privacy con security, legal, producto, procurement, data, HR y negocio.

Conserve policies, charters, RACI, minutas, issues y corrective actions.

Chapter 06 — Inventario y registros de tratamiento

Mantenga inventario actual de actividades, sistemas, datasets, propósitos, categorías, datos sensibles, titulares, bases legales, destinatarios, operadores, transferencias, retención, security controls y owners.

Actualice el inventario cuando cambien productos, vendors, propósitos, flujos, tecnologías o condiciones legales.

Chapter 07 — Bases legales y análisis de propósito/necesidad

Registre la base legal LGPD aplicable a cada propósito material y pruebe por separado legitimidad, adecuación y necesidad. No sustituya una base por consentimiento ni asuma que una base cubre usos secundarios no relacionados.

Conserve lawful-basis register, propósitos, necessity assessments, approvals, excepciones y fechas de revisión.

Chapter 08 — Gobernanza de consentimiento y retiro

Cuando el consentimiento sea la base, diseñe captura demostrable y específica y permita retiro mediante procesos controlados. Prevenga dark patterns, propósitos agrupados o continuidad de tratamiento tras retiro válido sin otra base documentada.

Conserve texto/versión, timestamp, origen, retiro, propagación downstream, excepciones y pruebas.

Chapter 09 — Legitimate-interest assessment y balancing

Cuando se use interés legítimo, documente propósito, necesidad, expectativas, impactos, safeguards, transparencia y conclusión de balance. Escale usos con intrusión relevante, datos sensibles, niños, monitoring, profiling o uso secundario inesperado.

Conserve assessment, hechos, controles mitigantes, aprobación y triggers de cambio.

Chapter 10 — Gobernanza de datos de niños y adolescentes

Trate datos de niños y adolescentes como área de gobernanza reforzada con análisis específico de aplicabilidad e interés superior. Preserve edad, procesos parentales cuando apliquen, transparencia, minimización, seguridad y product safeguards.

Conserve evaluación, notices, base/consent analysis, design review, pruebas, quejas y remediación.

Chapter 11 — Operaciones de derechos de titulares

Opere intake, validación de identidad, routing, búsqueda, decisión, respuesta, corrección, portability/change-watch, eliminación, objeción y escalamiento documentados. No prometa derechos o deadlines superiores a la fuente vigente salvo que se identifiquen como policy commitment.

Conserve request logs, identity evidence, búsquedas, decisiones, respuestas, excepciones y métricas.

Chapter 12 — Notices de transparencia y deberes de información

Mantenga notices alineados con tratamiento real, propósitos, sharing, derechos, identidad del controlador, contacto del encargado, transferencias y automatización material. Reconcilie notices con inventarios, contratos, productos y cambios.

Conserve versiones, approvals, fechas, change records, readability review y reconciliación con sistemas.

Chapter 13 — Calidad, minimización, retención, eliminación y anonimización

Recolecte y retenga solo datos necesarios, mantenga controles razonables de calidad y haga cumplir retention/deletion defendible. Trate claims de anonimización como conclusiones técnicas/jurídicas que requieren evidencia de riesgo de reidentificación.

Conserve schedules, deletion evidence, quality controls, anonymization assessments, excepciones y backup/disposal handling.

Chapter 14 — Privacy by design/default y change management

Integre privacidad en gates de producto, sistema, procurement, analytics, AI y procesos. Exija privacy review ante cambios materiales en propósito, categorías, destinatarios, transfers, profiling, monitoring o tecnología de alto riesgo.

Conserve checklists, architecture decisions, DPIA/risk artifacts, approvals, test results y change tickets.

Chapter 15 — Salvaguardas de seguridad y controles administrativos/técnicos

Implemente medidas administrativas, técnicas y físicas razonables según sensibilidad, volumen, amenazas, contexto e impacto. Integre IAM, configuración segura, logging, vulnerability management, encryption, resilience, secure development, monitoring e incident response.

Conserve mappings, testing evidence, vulnerabilities, excepciones, remediación y risk acceptance.

Chapter 16 — Incidentes y notificación a ANPD/titulares

Use proceso documentado alineado con la regulación vigente de comunicación de incidentes de ANPD. Determine si hay datos personales, evalúe daño/riesgo y criterios de notificación, preserve timing y coordine comunicaciones cuando sean legalmente requeridas.

Conserve hechos, assessment, autoridad decisoria, notifications, timestamps, remediación y lessons learned.

Chapter 17 — Risk assessment, privacy impact y tratamiento de alto riesgo

Aplique evaluaciones de riesgo e impacto a tratamiento material o high-risk, incluyendo escala, sensibles, grupos vulnerables, monitoring, profiling, nuevas tecnologías y decisiones automatizadas significativas. Use requisitos/solicitudes ANPD vigentes sobre impact reports cuando apliquen.

Conserve metodología, assessment, residual risk, safeguards, approvals y review cycle.

Chapter 18 — Transferencias internacionales y mecanismos

Aplique LGPD y la regulación vigente de ANPD a transfers cubiertas. Determine alcance, base legal, mecanismo válido, transparencia, onward transfer y safeguards. Preserve la rectificación de 2025 y decisiones de adecuación vigentes en source control.

Conserve transfer inventory, mecanismo, adequacy decision cuando se use, cláusulas o mecanismo aprobado, due diligence, contrato y reassessment.

Chapter 19 — Lifecycle de vendors, operadores y subprocesadores

Evalúe riesgo de operadores, subprocessors, cloud/SaaS y otros recipients antes y durante la relación. Defina instrucciones, propósito, security, rights assistance, incidents, transfers, retention, audit rights y exit.

Conserve due diligence, contratos, operator register, subprocessor changes, monitoring, issues y termination evidence.

Chapter 20 — Contratos, instrucciones, confidencialidad y responsabilidad compartida

Convierta requirements en instrucciones y términos claros sin permitir que etiquetas contractuales sustituyan roles legales reales. Identifique responsabilidades compartidas, security duties, rights support, transfers, incident cooperation y evidence retention.

Conserve executed terms, responsibility matrix, instruction history, confidentiality controls y amendments.

Chapter 21 — Cloud, SaaS, managed service y procesamiento transfronterizo

Mapee ubicaciones de datos, admins, subprocessors, telemetry, backups, support access, encryption, deletion, resilience y flujos internacionales. Resuelva transfer mechanism y operator responsibilities antes de producción.

Conserve cloud inventory, architecture/data-flow maps, shared responsibility, configurations, contracts, transfer assessments y exit plans.

Chapter 22 — Marketing, profiling, decisiones automatizadas y analytics

Gobierne marketing, profiling, analytics, personalización y automated decisions con base legal, transparencia, minimización, calidad, rights support, review mechanisms y anti-discrimination controls cuando apliquen. No exagere derechos legales sin análisis vigente.

Conserve use-case assessments, rules/models, notices, rights handling, review evidence, métricas y complaints/remediation.

Chapter 23 — Privacidad laboral, acceso, monitoring y training

Aplique LGPD a datos de empleados, candidatos y contractors separando requisitos laborales. Limite access y monitoring a propósitos documentados con proporcionalidad, transparencia, retención y escalation.

Conserve workforce notices, access reviews, monitoring assessments, retention, training, investigations y exceptions.

Chapter 24 — Registros físicos y datos no digitales

Incluya archivos en papel, visitors, medios físicos, correo y otros tratamientos no digitales cuando aplique LGPD. Controle storage, access, transport, copying, retention, destruction e incident handling.

Conserve inventories, access controls, disposal certificates, facility reviews e incident evidence.

Chapter 25 — Agentes de pequeño porte y tratamiento diferenciado

Determine si las reglas ANPD para pequeños agentes aplican y qué simplificaciones concretas existen. No trate el estatus como exención general de principios LGPD, seguridad, derechos u obligaciones no dispensadas.

Conserve eligibility analysis, simplifications, retained obligations, review triggers y evidence.

Chapter 26 — Regulaciones ANPD, guía, inspecciones, sanciones y readiness

Mantenga obligation register que distinga regulations vinculantes de guidance, FAQs, consultas, enforcement facts y agenda futura. Prepare evidence para fiscalización y sanciones sin convertir casos ajenos en reglas universales.

Conserve regulatory register, inspection protocol, legal holds, response packages, sanction analysis, findings y corrective actions.

Chapter 27 — Mapping de overlays sectoriales y leyes adyacentes

Mapee requisitos consumer, employment, financial, health, telecom, digital platform, child protection, cybersecurity, records y otros de Brasil separados de LGPD. Identifique controles adicionales sin atribuirlos a fuente equivocada.

Conserve overlay matrix, owners, citations, applicability decisions, conflicts y change watch.

Chapter 28 — Arquitectura de evidencia, audit trail y accountability

Diseñe trazabilidad entre requirement, owner, procedure, system/control, test, exception, remediation y decision. Proteja integrity, access, retention, confidentiality y version history.

Conserve evidence indexes, control maps, workpapers, approvals, logs, findings, remediation y provenance.

Chapter 29 — Excepciones, remediación, risk acceptance y reporting

Exija excepciones documentadas con scope, rationale, compensating controls, owner, approval, duration, residual risk y expiration. Escale issues vencidos o de alto impacto a management y liderazgo legal/privacy.

Conserve exception registers, corrective actions, risk acceptances, dashboards, escalation y closure evidence.

Chapter 30 — Regulatory change watch y triggers de reevaluación ANPD

Monitoree LGPD consolidada, regulaciones ANPD, amendments/rectifications, adequacy decisions, agenda regulatoria, priority topics, guidance material y cambios organizacionales que afecten aplicabilidad.

Conserve snapshots fechados, change assessments, owners, implementation plans, effective dates y candidate-supersession decisions.

Chapter 31 — Exact-hash review, localización, provenance y release evidence

Congele la fuente controlada antes de candidate generation. Vincule artefactos EN/es-419/pt-BR DOCX/PDF a SHA-256 exactos y preserve accessibility, render, source, localization, workflow-security y release-QA evidence.

Todo cambio material post-freeze requiere supersession, regeneración, re-hashing y re-review de gates afectados.

Chapter 32 — Roadmap, madurez y reverificación de release

Implemente por fases: applicability/inventory, governance/lawful bases, rights/notices, security/incidents, transfers/vendors, high-risk processing y assurance/evidence. Mida madurez mediante outcomes respaldados por evidencia.

Antes de publicar, reverifique LGPD consolidada, regulaciones/rectifications ANPD, incident rules, DPO, transfers/adequacy, small-agent treatment, sanctions/enforcement y overlays materiales. La publicación permanece secuencial después de Manual 35 y requiere todos los gates determinísticos en verde.